

SIEM / IDS ALERT INVESTIGATION REPORT: MALWARE COMMAND-AND-CONTROL & EXFILTRATION

DOCUMENT CONTROL

Table 1. Document Control

Attribute	Details
Organization	KifaruCart Global Ltd.
Document Title	SOC Incident Investigation: Malware C2 & Network Reconnaissance
Alert Reference ID	SOC-2026-0822-0047 / notable-2026-0822-0919-7741
Incident Date	August 22, 2026 (09:20:10 EAT)
Prepared By	SOC Security Analyst (Tier 2 Triage)
Affected Endpoint	WAREHOUSE-LT-07 (10.10.20.47)
Triage Verdict	TRUE POSITIVE (CRITICAL)

TABLE OF CONTENTS

Click any section title to navigate to that section.

EXECUTIVE SUMMARY 3

1. ALERT PROFILE & SIEM NOTABLE EVENT SUMMARY 3

 1.1 IDS Alert Summary Card 3

 1.2 Splunk SIEM Notable Event Profile 3

2. DETECTION TELEMETRY & RAW PAYLOAD ANALYSIS 4

 2.1 Raw Suricata IDS Alert (JSON Payload) 4

 2.2 Technical Payload Analysis 5

3. CORRELATED MULTI-SOURCE EVIDENCE 5

4. THREAT HUNTING & SPLUNK (SPL) QUERIES 6

5. CHRONOLOGICAL FORENSIC INVESTIGATION TIMELINE 7

6. TRIAGE DECISION, RISK SCORING & SEVERITY ASSESSMENT 7

 6.1 Triage Verdict: True Positive (Critical Incident) 7

 6.2 Severity Impact Matrix 7

7. PHASED INCIDENT RESPONSE RECOMMENDATIONS 8

8. ANALYST CONCLUSION & PORTFOLIO POSITIONING 9

 8.1 Analyst Conclusion 9

 8.2 Portfolio Positioning Statement 9

APPENDIX A: MITRE ATT&CK MAPPING & SOC TERMINOLOGY 10

LIST OF TABLES

Table 1. Document Control 1

Table 2. IDS Alert Summary Card 3

Table 3. Splunk SIEM Notable Event Profile 3

Table 4. Correlated Event Telemetry 5

Table 5. Severity Impact Matrix 7

Table 6. Immediate Containment Actions 8

Table 7. Investigation and Eradication Actions 8

Table 8. Recovery and Strategic Hardening Actions 9

Table 9. MITRE ATT&CK Mapping 10

LIST OF FIGURES

Figure 1. Multi-Source Log Correlation Timeline 5

EXECUTIVE SUMMARY

On August 22, 2026, at 09:20:10 EAT, the KifaruCart Security Operations Center (SOC) SIEM platform (Splunk) generated a High-Severity Notable Event triggered by Suricata Intrusion Detection System (IDS) signature 2026082201 (ET MALWARE Possible C2 Check-in via Suspicious HTTP POST). Telemetry correlated across endpoint logs, DNS queries, firewall state tables, and IDS alerts indicated an active malware infection originating from host WAREHOUSE-LT-07 (10.10.20.47).

Multi-source log correlation confirmed that at 09:16:55 EAT, an operational user executed a malicious link file (Shipping_Invoice_August.pdf.lnk), spawning an unauthorized payload (winupdate.exe). The malware subsequently initiated Domain Generation Algorithm (DGA) lookups, retrieved a second-stage payload (payload.bin), exfiltrated ~120 KB of data via HTTP POST sessions to external command-and-control (C2) nodes (203.0.113.45 and 198.51.100.77), and executed internal port scanning against critical database and administrative assets.

This report classifies the incident as a True Positive (Critical Severity). Immediate host containment, perimeter firewall blocking, credential revocation, and forensic triage are mandated.

1. ALERT PROFILE & SIEM NOTABLE EVENT SUMMARY

1.1 IDS Alert Summary Card

Table 2. IDS Alert Summary Card

Alert Attribute	Technical Value	Security Context
Alert ID	SOC-2026-0822-0047	Unique SOC tracking identifier.
Detection Engine	Suricata IDS -> Splunk SIEM	Network Intrusion Detection System forwarded to SIEM.
Signature Name	ET MALWARE Possible C2 Check-in via Suspicious HTTP POST	Emerging Threats malware signature rule.
Signature ID	2026082201	Rule ID for HTTP C2 POST detection.
Source Entity	10.10.20.47 (WAREHOUSE-LT-07)	Internal workstation (Warehouse VLAN).
Destination Entity	203.0.113.45:80 (HTTP)	External non-reputational IP destination.
Timestamp	2026-08-22 09:20:10 EAT	Initial signature trigger time.
Observed Action	Allowed (Pass)	IDS configured in detection mode; traffic passed firewall.

1.2 Splunk SIEM Notable Event Profile

Table 3. Splunk SIEM Notable Event Profile

SIEM Property	Value / Metric	Description
Splunk Notable ID	notable-2026-0822-0919-7741	Correlated event ID in Splunk Enterprise Security.
Correlation Rule	Possible Malware C2 Over HTTP	Multi-source event aggregation rule.
Risk Object	WAREHOUSE-LT-07 (10.10.20.47)	Affected system asset.
Calculated Risk Score	92 / 100	High risk due to correlated C2 + internal probes.
MITRE ATT&CK Tactic	Command and Control (TA0011)	Application Layer Protocol (T1071.001).
Correlated Events	17 Distinct Events	Includes DNS, Endpoint, IDS, and Firewall logs.
Assigned Status	Escalated to Incident Response	Handed over for P1 containment.

2. DETECTION TELEMETRY & RAW PAYLOAD ANALYSIS

2.1 Raw Suricata IDS Alert (JSON Payload)

JSON

```
{
  "timestamp": "2026-08-22T09:20:10.472+0300",
  "event_type": "alert",
  "src_ip": "10.10.20.47",
  "src_port": 49622,
  "dest_ip": "203.0.113.45",
  "dest_port": 80,
  "proto": "TCP",
  "app_proto": "http",
  "alert": {
    "signature_id": 2026082201,
    "signature": "ET MALWARE Possible C2 Check-in via Suspicious HTTP POST",
    "category": "A Network Trojan was detected",
    "severity": 1
  },
  "http": {
    "hostname": "203.0.113.45",
    "url": "/gate.php",
    "http_method": "POST",
    "protocol": "HTTP/1.1",
    "status": 200,
    "length": 72440,
    "http_user_agent": "Windows-Update-Agent"
  },
  "flow": {
    "pkts_toserver": 18,
    "pkts_toclient": 11,
    "bytes_toserver": 72440,
    "bytes_toclient": 1024
  }
}
```

2.2 Technical Payload Analysis

- **Anomalous Destination:** The request targets a raw IP address (203.0.113.45) rather than a fully qualified Microsoft update domain (*.microsoft.com).

- **Impersonated User-Agent:** The User-Agent header claims to be Windows-Update-Agent. Official Windows Update operations utilize encrypted HTTPS channels (Port 443) to verified Microsoft infrastructure, confirming header spoofing by an unauthorized process.
- **Suspicious C2 URI Path:** The request path /gate.php is a documented indicator of malware web panel gateways (e.g., HTTP-based botnet C2 software).
- **Asymmetric Data Flow:** bytes_toserver is registered at 72,440 bytes (~72.4 KB) while bytes_toclient is only 1,024 bytes. High outbound POST volume on an HTTP check-in endpoint indicates active data exfiltration or staging delivery.

3. CORRELATED MULTI-SOURCE EVIDENCE

Figure 1. Multi-Source Log Correlation Timeline

MULTI-SOURCE LOG CORRELATION		
09:16:55 EAT	ENDPOINT	User opens 'Shipping_Invoice_August.pdf.lnk'
09:17:12 EAT	ENDPOINT	Process 'C:\Users\Public\winupdate.exe' created
09:17:43 EAT	DNS	Lookup 'xj29sd-checkin.example' -> 203.0.113.45
09:18:40 EAT	FIREWALL	HTTP POST to 198.51.100.77 (/upload/logs) [48,920 Bytes Out]
09:19:27 EAT	IDS	HTTP GET to 203.0.113.45 (/payload.bin) [Payload Retrieval]
09:20:10 EAT	IDS/SIEM	HTTP POST to 203.0.113.45 (/gate.php) [72,440 Bytes Out - ALERT]
09:21:03 EAT	FIREWALL	TCP SYN Probe to 10.10.30.25:3306 (MySQL) -> BLOCKED
09:21:22 EAT	FIREWALL	TCP SYN Probe to 10.10.30.20:22 (SSH) -> BLOCKED
09:21:29 EAT	FIREWALL	TCP SYN Probe to 10.10.30.20:3389 (RDP) -> BLOCKED

Correlated Event Telemetry Table

Table 4. Correlated Event Telemetry

Source	Event Time	Log Metric / Summary	Technical Interpretation & Significance
Endpoint Log	09:16:55	Opened Shipping_Invoice_August.pdf.lnk	Initial Access: Social engineering / spear-phishing payload execution.
Endpoint Log	09:17:12	Executable created: C:\Users\Public\winupdate.exe	Execution: Drops unauthorized binary in public directory.
DNS Server	09:17:43	Query xj29sd-checkin.example -> 203.0.113.45	C2 Lookup: Initial resolution of command-and-control server.
Firewall	09:18:40	Outbound HTTP POST to 198.51.100.77/upload/logs	Data Staging: Exfiltrates 48.9 KB of initial host triage data.
DNS Server	09:19:03	TXT Query a91k2l3j4.example -> NXDOMAIN	DGA Activity: Fallback domain generation algorithm active.
IDS Alert	09:19:27	HTTP GET 203.0.113.45/payload.bin	Payload Retrieval: Downloads second-stage executable file.
IDS Alert	09:20:10	HTTP POST 203.0.113.45/gate.php (72.4 KB)	Exfiltration/C2: Primary alert trigger event.
Firewall	09:21:03	TCP SYN 10.10.20.47 -> 10.10.30.25:3306 (BLOCKED)	Reconnaissance: Unsolicited probe against MySQL Database.
Firewall	09:21:22	TCP SYN 10.10.20.47 -> 10.10.30.20:22 (BLOCKED)	Reconnaissance: Unsolicited probe against SSH Admin server.

Source	Event Time	Log Metric / Summary	Technical Interpretation & Significance
Firewall	09:21:29	TCP SYN 10.10.20.47 -> 10.10.30.20:3389 (BLOCKED)	Reconnaissance: Unsolicited probe against RDP Admin server.

4. THREAT HUNTING & SPLUNK (SPL) QUERIES

The following Splunk Processing Language (SPL) queries were executed to establish breach boundaries and verify the attack scope across the enterprise.

Query 1: Full Network Activity Trace for Compromised Host

Purpose: Extracts complete chronological network connections for the target host.

Splunk SPL

```
index=network src_ip="10.10.20.47"
| table _time src_ip dest_ip dest_port protocol action bytes_out
| sort _time
```

Query 2: External Infrastructure Exposure & Host Correlation

Purpose: Identifies all internal assets attempting communication with identified C2 IP addresses.

Splunk SPL

```
index=network (dest_ip="203.0.113.45" OR dest_ip="198.51.100.77")
| stats count min(_time) as first_seen max(_time) as last_seen values(src_ip) as internal_hosts by dest_ip
```

Query 3: DNS Query & Algorithmic Domain Audit

Purpose: Audits all DNS queries issued by WAREHOUSE-LT-07 to track DGA resolution patterns.

Splunk SPL

```
index=dns src_ip="10.10.20.47"
| table _time src_ip query query_type response
| sort _time
```

Query 4: Scope Verification across Enterprise Subnets

Purpose: Verifies whether any other workstation has contacted identified C2 infrastructure.

Splunk SPL

```
index=network (dest_ip="203.0.113.45" OR dest_ip="198.51.100.77")
| stats count values(dest_port) as ports values(action) as actions by src_ip
```

Query 5: Internal Network Scanning & Sweep Detection

Purpose: Audits horizontal port scanning attempts targeting server VLAN 10.10.30.0/24.

Splunk SPL

```
index=network src_ip="10.10.20.47" dest_ip="10.10.30.0/24"
| stats count values(dest_port) as attempted_ports values(action) as results by dest_ip
```

5. CHRONOLOGICAL FORENSIC INVESTIGATION TIMELINE

09:16:55 EAT - Initial Execution: User opens Shipping_Invoice_August.pdf.lnk

09:17:12 EAT - Malware Dropper Created: C:\Users\Public\winupdate.exe

09:17:43 EAT - C2 Beaconing Initiated: DNS resolution for xj29sd-checkin.example

09:18:40 EAT - Initial Data Staging: HTTP POST to 198.51.100.77 (48.9 KB Out)

09:19:27 EAT - Second-Stage Download: HTTP GET /payload.bin

09:20:10 EAT - C2 Exfiltration Alert: HTTP POST to /gate.php (72.4 KB Out) [TRIGGER]

09:21:03 EAT - Lateral Reconnaissance: TCP SYN to MySQL Server (3306) [BLOCKED]

09:21:22 EAT - Lateral Reconnaissance: TCP SYN to Admin Server (22) [BLOCKED]

09:21:29 EAT - Lateral Reconnaissance: TCP SYN to Admin Server (3389) [BLOCKED]

6. TRIAGE DECISION, RISK SCORING & SEVERITY ASSESSMENT

6.1 Triage Verdict: True Positive (Critical Incident)

The alert is formally declared a True Positive. The correlation of four independent security telemetry sources (Endpoint, DNS, IDS, and Firewall) confirms active host compromise, secondary binary download, data exfiltration, and internal network reconnaissance.

6.2 Severity Impact Matrix

Table 5. Severity Impact Matrix

Impact Dimension	Assessment	Operational Justification
Confidentiality Impact	High	Over 120 KB of host data exfiltrated via HTTP POST requests (/upload/logs, /gate.php).
Integrity Impact	High	Unauthorized executable creation (winupdate.exe, payload.bin) and system file modifications.
Availability Impact	Medium	Risk of lateral malware spread or ransomware execution across server subnets.
Likelihood of Recurrence	High	Active phishing vector present; lack of automated endpoint isolation.
Overall Severity	CRITICAL	Priority 1 (P1) Incident Response Activation Required.

7. PHASED INCIDENT RESPONSE RECOMMENDATIONS

Phase 1: Immediate Containment Actions (0 – 2 Hours)

Table 6. Immediate Containment Actions

Priority	Action Item	Target System	Responsible Owner	Technical Objective
P1	Isolate Endpoint: Sever network connections (WLAN/Ethernet) for WAREHOUSE-LT-07.	10.10.20.47	SOC / IT Support	Terminate active C2 sessions and prevent lateral spread.
P1	Egress Block: Add IP addresses 203.0.113.45 and 198.51.100.77 to firewall blocklists.	Firewall Gateway	Network Engineer	Block external C2 communication network-wide.
P1	Credential Revocation: Disable user account and terminate active M365/cloud sessions.	User Account	Identity Admin	Prevent stolen credential misuse across portals.
P1	Forensic Preservation: Capture volatile RAM and preserve local event logs.	WAREHOUSE-LT-07	Forensic Analyst	Preserve volatile evidence for malware analysis.

Priority	Action Item	Target System	Responsible Owner	Technical Objective
P1	SIEM Enterprise Sweep: Run SPL Query 4 to verify whether other endpoints contacted C2 IPs.	Splunk SIEM	SOC Analyst	Establish total scope of breach.

Phase 2: Investigation & Eradication (24 – 48 Hours)

Table 7. Investigation and Eradication Actions

Priority	Action Item	Target System	Responsible Owner	Technical Objective
P1	Host Forensic Triage: Analyze winupdate.exe and payload.bin for persistence mechanisms.	Forensic Image	Forensic Analyst	Identify registry run keys, scheduled tasks, and drop paths.
P1	Phishing Vector Analysis: Audit email gateway logs for Shipping_Invoice_August.pdf.lnk.	Email Security	SOC Analyst	Identify sender address, purge message from all mailboxes.
P2	Server Log Audit: Review MySQL (10.10.30.25) and Admin (10.10.30.20) audit logs.	Server Infrastructure	Database / SysAdmin	Confirm zero unauthorized database or SSH access occurred.
P2	System Wipe & Reimage: Reimage WAREHOUSE-LT-07 OS from clean golden master image.	Workstation	IT Support	Ensure total eradication of malware components.

Phase 3: Recovery & Strategic Hardening (30 Days)

Table 8. Recovery and Strategic Hardening Actions

Priority	Action Item	Target System	Responsible Owner	Strategic Outcome
P2	Deploy Centralized EDR: Roll out Endpoint Detection & Response agent to all laptops.	All Endpoints	IT Manager	Enable automated process termination and host isolation.
P2	DNS Security Gateway: Deploy DNS filtering (e.g., Cisco Umbrella) network-wide.	DNS Architecture	Network Engineer	Block DGA lookups and malicious domain resolutions.
P2	VLAN Micro-segmentation: Enforce ACLs restricting Warehouse VLAN access to Admin subnets.	Firewall / Switches	Network Engineer	Prevent internal network scanning and lateral probes.
P2	SIEM Exfiltration Alerting: Configure SPL rules alerting on HTTP POST byte spikes > 50 KB.	Splunk SIEM	SOC Lead	Detect future data exfiltration attempts automatically.
P2	Phishing Simulation: Conduct targeted training for Warehouse Operations personnel.	Staff Workforce	HR + SOC	Reduce human susceptibility to malicious attachments.

8. ANALYST CONCLUSION & PORTFOLIO POSITIONING

8.1 Analyst Conclusion

The SIEM/IDS alert investigation for WAREHOUSE-LT-07 confirms a successful endpoint compromise via a malicious link file attachment, leading to C2 check-in, payload retrieval, outbound data exfiltration, and internal network probing. Timely firewall block rules mitigated lateral movement attempts against production database assets. Full execution of the phased containment and eradication roadmap will restore system integrity and eliminate the identified threat vector.

8.2 Portfolio Positioning Statement

Portfolio Reference Statement: Investigated a confirmed SIEM/IDS True Positive alert involving malware C2 check-in, data exfiltration, and lateral reconnaissance at KifaruCart Global Ltd. Analyzed raw Suricata JSON payloads, Splunk notable events, DNS queries, firewall connection tables, and endpoint process logs. Executed threat hunting queries in Splunk (SPL), constructed a forensic attack timeline, assigned severity ratings, and authored a phased Incident Response containment and hardening plan.

APPENDIX A: MITRE ATT&CK MAPPING & SOC TERMINOLOGY

MITRE ATT&CK Framework Mapping

Table 9. MITRE ATT&CK Mapping

Tactic	Technique Name	ID	Observed Evidence in Incident
Initial Access	Phishing: Malicious Link	T1566.002	User opened Shipping_Invoice_August.pdf.lnk.
Execution	User Execution	T1204.002	Executed shortcut link file spawning winupdate.exe.
Command & Control	Application Layer Protocol	T1071.001	HTTP POST sessions to /gate.php on 203.0.113.45.
Command & Control	Dynamic Resolution: DGA	T1568.002	TXT queries to algorithmic domains (a91k2l3j4.example).
Exfiltration	Exfiltration Over C2 Channel	T1041	Transmitted 72.4 KB outbound via HTTP POST requests.
Discovery	Network Service Discovery	T1046	TCP SYN probes targeting ports 22, 3306, and 3389.

SOC Terminology Glossary

- **Suricata IDS:** An open-source, high-performance Network Intrusion Detection System (NIDS) utilizing signature-based detection rules.
- **Splunk SIEM:** Security Information and Event Management platform that aggregates, correlates, and analyzes security logging data across enterprises.
- **True Positive:** A security alert that correctly identifies actual malicious activity or a policy violation requiring containment.
- **Command-and-Control (C2):** Infrastructure operated by attackers to maintain communication with infected endpoints, issue commands, and exfiltrate data.